

AHS Vault — UK Enterprise-Ready

PDF 1 of 2: What You Can Do INSTANTLY — Docs + Code / README / File Edits

B2B SaaS | You-host relay + BYO Drive | Finance + NHS + Gov | UK Ltd exists | Date: 2026-09-11

This PDF is ONLY the no-permission work: files and docs you create/fix **today in this repo, £0, no auditor, no government wait**. Every item gives **file path + line + old -> new + command to verify**. Do this first — PDF 2 (sign/fee/govt) will FAIL until these are done.

A. Docs you create instantly (£0, no sign-off needed for draft)

DOC	LICENSE (missing — blocks legal day one)	CREATE NOW
-----	--	------------

Source: File: G:\ahs\ahs-app\LICENSE (create). Verified: Test-Path LICENSE = False; README.md:5 badge and :420 link to dead LICENSE; package.json x2 private:true with no license field; Cargo.toml no license=; go.mod no licence.

How:

- Pick ONE: proprietary commercial (recommended B2B) or MIT. Do not keep MIT badge with private:true.
- Write LICENSE text. If proprietary: 'Copyright (c) [Ltd name, company no.] All rights reserved. No copying/distribution without licence. Contact [email].'
- Verify: Test-Path ./LICENSE ; fix README links to ./LICENSE.

DOC	NOTICE / THIRD_PARTY + SBOM per component	CREATE NOW
-----	---	------------

Source: Files: vault-web-auth/package.json, vault-desktop-tauri/package.json, src-tauri/Cargo.toml (+Cargo.lock), vault-backend-go/go.mod, vault-mobile-auth/app/build.gradle.kts. Output: docs/SBOM/ + NOTICE.

How:

- Web: cd vault-web-auth && npx @cyclonedx/cdxgen -o ../docs/SBOM/sbom-web.json
- Desktop JS: cd vault-desktop-tauri && npx @cyclonedx/cdxgen -o ../docs/SBOM/sbom-desktop.json
- Rust: cargo install cargo-cyclonedx; cd vault-desktop-tauri/src-tauri && cargo cyclonedx -o ../docs/SBOM/sbom-rust.json
- Go: cd vault-backend-go && cyclonedx-gomod mod -json -o ../docs/SBOM/sbom-go.json
- Android: list from app/build.gradle.kts (compose-bom, cameraX, mlkit, tink, okhttp, biometric) into sbom-mobile.json
- Build NOTICE from licences found. Verify: Get-ChildItem docs/SBOM/

DOC	SECURITY.md (missing — PSTI + CVD contact)	CREATE NOW
-----	--	------------

Source: File: G:\ahs\ahs-app\SECURITY.md (create). No SECURITY.md exists today.

How:

- Add: supported versions (e.g. desktop 0.1.x, backend main), report channel (security@[domain], PGP optional), SLA (ack 48h), scope (relay/API/desktop/web/mobile, NOT Google Drive itself), PSTI support period, CVD policy (NCSC).
- Verify: Test-Path ./SECURITY.md

DOC	API spec + DB schema doc	CREATE NOW
-----	--------------------------	------------

Source: Files: vault-backend-go/internal/api/router.go:36-71 (all routes), handlers.go, web_handlers.go, db.go:60-84 tables, README.md:261-347.

How:

- Write docs/OPENAPI.yaml enumerating: POST /api/vault/upload|pair|push|shield/log/register, GET /api/vault/download/{id}|devices|activity|stats|index, POST /api/vault/index|delete, GET /api/ws/connect, POST /api/web/pair|push|register-webauthn, GET /api/web/ws/connect, GET /health/api/update + headers X-Desktop-PK/X-Signature/X-Google-Token + WS JSON (desktop_register, mobile_register, unlock_approved, push_relay, WAKE_UP_BIOMETRIC).
- Write docs/DATABASE.md from db.go + README schema (devices/activity_logs capped LIMIT 50/blobs). Verify: open OPENAPI.yaml in Swagger UI.

DOC	Architecture + Data-flow + Threat-model + Whitepaper drafts	CREATE NOW
-----	---	------------

Source: Files: README.md:18-64,144-258; PROJECT.md; Project_Overview.txt; docs/MOBILE_FLOW_ANALYSIS.md; crypto.rs, crypto.ts, CryptoManager.kt, fs.rs, network.rs, hub.go, gdrive.go.

How:

- docs/ARCHITECTURE.md (C4: Context/Container/Component/Code with file:line refs).
- docs/DATA_FLOWS.md (upload/download/delete/index/push relay + residency map: UK users -> relay host -> Drive US/EU -> GitHub US; mark ciphertext-only + sizes/counts + tokens visible).
- docs/THREAT_MODEL.md (STRIDE+LINDDUN rows pointing at router/handlers/webauthn/shield lines below).
- docs/WHITEPAPER.md (2-page exec + 15-page crypto: AES-256-GCM 128KB, BIP-39, X25519+AES-GCM wire base64(32B PK||12B nonce||ct), Ed25519, P-256, PBKDF2-310k; note mobile PIN parity bug).

DOC	Single runbook (kill 2-guide conflict)	CREATE NOW
-----	--	------------

Source: Files: PRODUCTION_SETUP_GUIDE_V2.md (says PASSWORD=ahs2026) vs PRODUCTION_SETUP_GUIDE.txt (says blank, v0.1.1 vs 0.1.20). Plus docker-compose.prod.yml, Dockerfile, .github/workflows/build-windows.yml + build-mobile.yml, tauri.conf.json.

How:

- Create docs/DEPLOYMENT.md as ONLY guide; archive the two old files to docs/archive/. Include: backend :8080 + postgres:15-alpine, env table (DATABASE_URL/GOOGLE_DRIVE_CREDENTIALS/PORT/TAURI_*), updater flow (tauri.conf endpoints + pubkey + HandleUpdate handlers.go:123 + tag v* rule), mobile assembleDebug note.
- REMOVE all secrets from doc (see B1). Reference GitHub Secrets. Verify: only DEPLOYMENT.md mentions release steps.

DOC	Scans you run now (only instant security evidence)	CREATE NOW
-----	--	------------

Source: Files: package-lock.json x2, Cargo.lock, go.mod. Output: docs/scans/. Nothing committed today.

How:

- cd vault-web-auth && npm audit --json > ../docs/scans/npm-web.json
- cd vault-desktop-tauri && npm audit --json > ../docs/scans/npm-desktop.json
- cargo install cargo-audit; cd vault-desktop-tauri/src-tauri && cargo audit --json > ../../docs/scans/cargo.json
- go install golang.org/x/vuln/cmd/govulncheck@latest; cd vault-backend-go && govulncheck ./... > ../docs/scans/govuln.txt
- gitleaks detect --source . --report-path docs/scans/gitleaks.json (EXPECT hits: Tauri key + oauth secret — keep as rotation evidence).
- Verify: Get-ChildItem docs/scans/ ; add same commands to .github/workflows CI gate.

B. Code edits you make instantly (each blocks Cyber Essentials / pen test / DPIA)

Order by fail-risk. Each: file:line, old -> new. No new infra needed.

FIX	B1. ROTATE + PURGE leaked secrets (do FIRST — 1 hour)	EDIT NOW
-----	---	----------

Where: Files: PRODUCTION_SETUP_GUIDE_V2.md:20-24 (live TAURI_SIGNING_PRIVATE_KEY base64 + PASSWORD=ahs2026) | vault-desktop-tauri/src-tauri/src/oauth.rs:18,98 hardcoded client_secret GOCSPX-dsPSy... | .env.example / docker-compose defaults vault_secret_123 | vault-desktop-tauri/test.key + test.key.pub (shipping private test key).

Change:

- Generate new Tauri key (tauri signer generate), put private in GitHub Settings>Secrets>Actions (TAURI_SIGNING_PRIVATE_KEY + PASSWORD), update tauri.conf.json pubkey ONLY. NEVER paste private into md again.
- Move Google OAuth id/secret to env (GOOGLE_CLIENT_ID/SECRET) + GitHub Secrets; read via env in oauth.rs; delete hardcoded strings.
- Rotate DB passwords, delete test.key/test.key.pub from repo, purge git history (BFG/filter-repo) + revoke old key/signature.
- Verify: grep -r TAURI_SIGNING_PRIVATE_KEY --include=*.md (expect 0 hits); grep -r GOCSPX (expect 0); Test-Path vault-desktop-tauri/test.key (False).

Note: Rotate now even before PDF-2 audits; old key in git = compromised.

FIX	B2. CORS wildcard — lock to allowlist (30 min)	EDIT NOW
-----	--	----------

Where: Files: vault-backend-go/internal/api/router.go:14-23 computes allowedOrigins correctly then IGNORES it; :28 AllowedOrigins * ; :59-65 second * for /api/web; handlers allow empty Origin (desktop WS) + web_handlers return true.

Change:

- Change :28 to AllowedOrigins: allowedOrigins (use the var). Change /api/web block to explicit list (e.g. https://app.[yourdomain], https://ahs.[yourdomain]) — no *.
- WS: validate Origin + require pairing_nonce/signature on BindIdentity (hub.go:54-75, handlers.go:555-575); reject empty Origin in prod.
- Verify: grep AllowedOrigins (no """); curl -H Origin:https://evil.test should NOT get ACAO:*

FIX	B3. Plaintext transport + DB + timeouts + rate limit (half day)	EDIT NOW
-----	---	----------

Where: Files: cmd/api/main.go:48-62 ListenAndServe :8080, Read/Write/IdleTimeout 1h (slow-loris) | db.go:32 sslmode=disable | minio.go useSSL=false | Dockerfile EXPOSE 8080 CMD ./vault-server (no certs) | router.go:25-26 only Logger+Recoverer (no throttle).

Change:

- Terminate TLS at reverse proxy (Caddy/Nginx) or ListenAndServeTLS + HSTS; set sslmode=require (prod) via env; useSSL=true.
- Tighten timeouts (e.g. Read 15s, Write 30s, Idle 60s) + cap UploadVault temp streaming (handlers.go:411-418 unbounded os.CreateTemp = disk exhaustion) with MaxBytesReader + quota.
- Add chi rate-limit (throttle) per IP + per public_key on /pair/push/upload/register-webauthn; cache GitHub /api/update (HandleUpdate) + optional PAT to avoid 60/hr DoS.
- Verify: https only + HSTS header; sql logs show sslmode=require; k6 abuse test 429s.

FIX	B4. AuthZ holes — require signatures everywhere (1-2 days, biggest CISO flag)	EDIT NOW
-----	---	----------

Where: Files: handlers.go:77-121 GetDevices/GetActivity/GetStats (trust ?public_key=, return ALL users if omitted), :191-244 Register/DeleteDevice (?public_key + bulk by name+os db.go:133-136), :684-731 RelayPush ZERO signature (anyone knowing target PK spams victim), :369-387 LogThreat unauth forgeable, signatures replayable (no nonce/timestamp), payload inconsistency (sign SHA256(body) vs blobID vs raw body).

Change:

- Require Ed25519/ECDSA sig on EVERY public_key-scoped route + WS BindIdentity; add nonce+timestamp (reject >5 min, single-use via hub nonce store); standardise ONE signed payload (e.g. method|path|bodyHash|nonce|ts).
- Fix GetStats/GetActivity: never return all users; scope strictly to verified PK. Narrow DeleteDevices to explicit ids. Auth LogThreat or drop client free-text (allowlist event_type/title, cap length, escape).
- Verify: unauth curl without sig = 401; omitted ?public_key= = 401 not dump; replayed sig = 401; RelayPush without sig = 401.

FIX	B5. Harden custom WebAuthn (half day)	EDIT NOW
-----	---------------------------------------	----------

Where: File: vault-backend-go/internal/auth/webauthn.go:34-109 manual authData+SHA256(clientData)->ecdsa.VerifyASN1; parses rpId/origin but never checks; ignores type==webauthn.get, UV/UP flags, signCount; challenge fallback strings.Contains.

Change:

- Enforce: exact challenge ==, origin allowlist (https://app.[domain], no raw IP), rpId == registered, type==webauthn.get, UP==1 (+UV per policy), signCount > stored (clone detection), verify credential id ownership. Remove Contains fallback.
- Add webauthn_test.go cases for each reject. Verify: go test ./internal/auth -v passes; IP-origin + replayed assertion rejected.

FIX	B6. Encrypt local keys + unify PIN KDF (1-2 days, DPIA blocker)	EDIT NOW
-----	---	----------

Where: Files: desktop lib.rs OnboardingConfig onboarding.json PLAINTEXT (mnemonic+signing_key+x_secret+google tokens) + local_index.json plaintext + export_vault_archive copies config dir | web db.ts Dexie IndexedDB unencrypted (PIN/WebAuthn gate only) | mobile SecureStorageManager OK (EncryptedSharedPreferences) BUT MainActivity PIN = single SHA-256(salt||pin) vs web crypto.ts:112-128 PBKDF2-310k.

Change:

- Desktop: encrypt onboarding.json at rest (OS keychain: keyring/secret-service/DPAPI/Keychain) + zeroize RAM on lock (already clear_master_key) + exclude secrets from export archive or encrypt archive.
- Web: wrap Dexie fields (master_key, x_private, mnemonic) with AES-GCM key from PIN (PBKDF2-310k) + WebAuthn PRF where available; wipe on lock/visibilitychange (already robustOpen).
- Mobile: upgrade PIN to PBKDF2/Argon2id matching web params; migration path for existing single-SHA hashes. Document KDF params in crypto spec.
- Verify: strings onboarding.json shows NO mnemonic; grep pin_hash params equal web==mobile.

FIX	B7. Stop logging secrets/PII (1 hour)	EDIT NOW
-----	---------------------------------------	----------

Where: Files: middleware.Logger logs IP/method/URI incl ?public_key= + X-Google-Token presence | hub.go:74 logs full public_key+nonce (use keyFingerprint() like handlers.go:65-71/hub.go:35-41) | handlers.go:642 logs full approvalJSON (encrypted_key).

Change:

- Custom logger: redact query (?public_key=***), headers (X-Google-Token ***), body token fields; replace all log.Printf(%s, pubkey/nonce/blob) with fingerprint (first 8 hex). Never log mnemonic/refresh_token/approvalJSON.
- Verify: grep log.Printf.*public_key|nonce (only fingerprint calls); tail server.log shows ***.

FIX	B8. IMAP shield + Downloads watch behind opt-in (half day, GDPR Art.5)	EDIT NOW
-----	--	----------

Where: File: vault-desktop-tauri/src-tauri/src/shield.rs:43 run_mail_shield (imap.gmail.com:993 default, SELECT INBOX, SEARCH UNSEEN, FETCH RFC822 full bodies incl attachments, Regex urls vs blocklist incl bit.ly/tinyurl, emit threat-detected; creds VAULT_IMAP_USER/PASS plaintext env) + run_file_shield polls ~/Downloads every 30s for exe/bat/msi/sh/scr/vbs created<65s.

Change:

- Gate BOTH behind explicit in-app opt-in (default OFF); when ON: minimise (headers+urls only, no full body), redact subject/detail before POST /api/vault/shield/log, document lawful basis (consent) + retention, store IMAP creds in OS keychain not env, allow per-folder scope + off switch. Update Privacy Notice + LIA.
- Verify: fresh install sends ZERO IMAP/Downloads events until opt-in; shield log contains no body text.

FIX	B9. Privacy leaks: Google Fonts + updater + WS (1 hour)	EDIT NOW
-----	---	----------

Where: Files: vault-desktop-tauri/src/index.css:2 @import fonts.googleapis.com (external US fetch on every load) | tauri.conf.json:50-53 updater endpoints https://ahs.mayfairmarketing.online/api/update (unauth GitHub 60/hr) | mobile MainActivity.kt:191 update check ACTION_VIEW url.

Change:

- Self-host Manrope+JetBrains Mono (download woff2 to src/assets/fonts, remove @import). Cache /api/update server-side + add PAT Authorization to raise 5k/hr. Pin mobile update URL to https + cert. Verify: grep fonts.googleapis (0 hits); offline load uses local fonts.

FIX	B10. Repo hygiene: remove bloat + test keys + version drift (1 hour)	EDIT NOW
-----	--	----------

Where: Files: vault-desktop-tauri/test.key + .pub (MUST delete) | jdk17.zip (190MB) + jdk17/ vendored + vault_4containers_*.tar.gz (48MB) | tauri.conf.json:23 csp null + version 0.1.20 must match package.json | PRODUCTION_SETUP_GUIDE_* conflict.

Change:

- git rm test.key*; move JDK to CI cache (actions/setup-java temurin:17) not repo; move tar.gz to Releases; set CSP (not null) for Tauri webview; keep version single-sourced + tag rule (30-31 in old guide). Add .gitignore for *.key, server.log, vault_local_db.json (0644 legacy json_db.go).
- Verify: du -sh (drop ~250MB); Test-Path test.key False; grep version matches.

C. README + guide edits (copy/paste checklist)

- README.md:5 badge + :420 text claim MIT but LICENSE missing — after creating LICENSE, change badge to ./LICENSE and text to match (proprietary wording if B2B, not MIT). Remove private:true contradiction (add license field to both package.json + Cargo.toml license=/repository=).

- README.md:18-33 How It Works + :230-258 crypto table + :261-347 schema: keep, but add honest limits box (plaintext transport until B3, CORS locked after B2, authZ enforced after B4, KDF parity after B6, IMAP opt-in after B8). Buyers trust honest limits.
- README.md:351-389 Deployment: replace inline compose yaml with link to docs/DEPLOYMENT.md (single source); env table add HTTP_ALLOWED_ORIGINS, DB_* + GOOGLE_* via env, PORT, TAURI_* via Secrets; delete passwords from docs.
- tauri.conf.json: productName/version/identifier com.britsync.ahs-vault + updater endpoints/pubkey: after B1 rotation update pubkey here + keep version in sync with package.json + tag v* (old guide steps 30-40). Set app.security.csp from null to strict policy.
- PROJECT.md + Project_Overview.txt + docs/MOBILE_FLOW_ANALYSIS.md: keep as history; add header pointing to new docs/ARCHITECTURE.md + WHITEPAPER.md + DEPLOYMENT.md as canonical.
- Delete/archive: PRODUCTION_SETUP_GUIDE_V2.md + PRODUCTION_SETUP_GUIDE.txt (move to docs/archive/ after DEPLOYMENT.md done); delete test.key*; ignore server.log, vault_local_db.json, jdk17.zip.

Verify README pass:

```
grep -n LICENSE README.md # must hit ./LICENSE, no dead link
grep -rn 'AllowedOrigins.*\*' vault-backend-go/ # expect 0 after B2
grep -rn 'GOCSPX\|TAURI_SIGNING_PRIVATE_KEY.*==' --include=*.md --include=*.rs . # expect 0 after B1
grep -rn 'fonts.googleapis' vault-*/src/ # expect 0 after B9
Test-Path ./LICENSE; Test-Path ./SECURITY.md; Get-ChildItem docs/SBOM/, docs/scans/
```

D. Order to do it today (fastest unblock first)

- 1. **B1 secrets rotation + test.key delete + LICENSE + SECURITY.md** — 1-2h, unblocks everything.
- 2. **B7 log redaction + B2 CORS + B10 hygiene + C README fixes** — 2-3h.
- 3. **Scans + SBOM (A)** — 1-2h, only instant security evidence.
- 4. **B3 TLS/timeouts/limits + B9 fonts/updater cache** — half day.
- 5. **B4 authZ + B5 WebAuthn** — 1-3 days, biggest pen-test flag.
- 6. **B6 key encryption + KDF unify + B8 IMAP opt-in** — 2-3 days, DPIA blockers.
- 7. **OPENAPI + ARCH + FLOWS + THREAT + WHITE + DEPLOYMENT docs** — parallel, 2-3 days.

End of PDF 1. When all boxes ticked, move to PDF 2 (sign / fee / govt). Do not book paid audits until B1-B4 + B6 + B8 are verified.